

HRIS Manila Council

Comparison of Old HRIS and New HRIS

Leave Management Module · Setup & Security Parameters
Tracked Changes, Fixes & Vulnerability Assessment

Document	Old vs New HRIS — Evidence-Based Comparison
Prepared for	Management / Project Governance
System	HRIS Manila Council (manilacitycouncil.com)
Report date	13 July 2026
Classification	Internal — contains security findings

Executive Summary

- **New capability:** a full Leave Management module — CS Form 6, Leave Card ledger, settings, PDF exports (32 files, ~3,120 lines) `d0d8be0`
- **Security hardening:** server-side authorization enforced on leave endpoints — closes privilege escalation & IDOR `b10c18b`
- **Earlier remediation:** PDS self-edit given real backend ownership checks `EMPLOYEE_PDS_EDIT_CHANGES.md`
- **Quality:** 5 additive PDS enhancements; clean build, ~92 MB WAR, Java 11 / Spring Boot 2.2.4

Bottom line: the New HRIS is both larger in capability and stronger in security — shifting from "*authenticated users are trusted*" to "*actions authorized by role and ownership*."

Scope of Review

Documentation / back-search task — no code changed to produce this.

Old HRIS

System before this engagement: PDS, appointments, clearance, service record, 201 files — with UI-level access restrictions.

New HRIS

Adds Leave Management, PDS enhancements, and server-side authorization hardening.

Sources back-searched

Commit history · change logs (CHANGES_SUMMARY, RUNTIME_ASSESSMENT_REPORT, EMPLOYEE_PDS_EDIT_CHANGES, LEAVE_MODULE_BLUEPRINT) · migrations · source (SecurityConfig, leave package) · UAT screenshots

Old HRIS Overview

Modules

- Personal Data Sheet (CS Form 212)
- Appointments · Clearance
- Service Record · 201 Files
- System Settings · Auth / Change Password

Stack

- Java 11 · Spring Boot 2.2.4
- WAR + embedded Tomcat (~92 MB)
- MySQL hris_01 · JasperReports
- nginx + Let's Encrypt · live at manilacitycouncil.com

Security characteristic: restrictions enforced in the *browser*; the backend authorized requests only as "any authenticated user." Root of the Section 9 findings. `EMPLOYEE_PDS_EDIT_CHANGES.md`

New HRIS Overview

Old HRIS

- PDS, Appointments, Clearance, Service Record, 201 Files
- PDS: HR/Admin edit only
- UI restrictions; backend trusts any authenticated user
- No leave processing

New HRIS

- All of the above + **Leave Management**
- PDS employee self-edit with ownership checks
- Role gating on leave admin/mutation endpoints
- PDS enhancements ×5 · leave-type & holiday settings

Added Module: Leave Management

Workflow

- Record CS Form 6 application
- Auto-certify VL/SL credits
- Recommend → Approve / Disapprove (exigency = no deduction)
- Post to Leave Card ledger
- Export Form 6 & Leave Card PDF

Data model `2026-leave-management.sql`

- leave_application — Form 6
- leave_card_entry — ledger
- leave_type · holiday — settings
- FKs → employee

Ledger: monthly accrual 1.25 VL + 1.25 SL; only "V"/"S" entries deduct; special leaves recorded without changing balances. Employees get a **read-only** /my-leaves view.

Setup & Security Parameters

Setup

- JDK 11 · Maven → target/hrisp.war
- MySQL hris_01
- Profiles: SPRING_PROFILES_ACTIVE (dev/prod)
- Secrets: DB_USERNAME/PASSWORD,
EMPLOYEE_DEFAULT_PASSWORD (env, not committed)

Security

- Form login · MigratingPasswordEncoder (BCrypt)
- Roles: ROLE_ADMIN / HR / EMPLOYEE
- empHashCode capability token on self-service
- CSRF on (leave POSTs protected)
- Upload allow-list + 5 MB cap

Migration order: back up DB → apply 2026-leave-management.sql + PDS migrations (additive) → deploy WAR → restart.

SECTION 7

List of HRIS Changes

Change	Type	Evidence
Leave module (Form 6, ledger, PDFs, settings)	FEATURE	d0d8be0
PDS enhancements ×5 (photo, L&D, part-time, date, GSIS)	FEATURE	CHANGES_SUMMARY
PDS self-edit + backend ownership checks	SECURITY	093043f
PDS validation bug (HR-only fields)	FIX	e906631
Clearance null-safe PDF / ID / binding	FIX	5cb1379
Leave role gating + Form 6 IDOR fix	SECURITY	b10c18b

Fixes Implemented

Leave authorization b10c18b

```
.antMatchers(LEAVE_ADMIN).hasAnyAuthority("ROLE_ADMIN","ROLE_HR")    // gate admin/mutations  
// /leaveForm6Pdf/{id}: own-record-or-staff, else 403 (IDOR fix)
```

PDS self-edit access control EMPLOYEE_PDS_EDIT_CHANGES.md

```
isOwnRecord = actor.getId() == entity.getEmployee().getId();  
if (!isAdmin && !isOwnRecord) return denied;    // no cross-employee edit  
if (!isAdmin) employee.setUserType(old.getUserType()); // no self-promotion
```

Also: PDS validation bug fixed (HR-only fields restored from DB) e906631; clearance robustness 5cb1379.

Vulnerability Assessment — Old HRIS

Finding	Sev.	Exploit
PDS saves — no backend authorization	HIGH	Any authenticated user edits others' PDS / escalates userType
Leave mutations — broken access control	HIGH	Self-approve leave, inflate credits, IDOR-delete records
Form 6 PDF — IDOR	MED	Enumerate ids → download anyone's PII
Uniform default password	MED	Guessable accounts without forced rotation

Root cause: authentication was conflated with authorization — the security boundary lived only in the browser.

Vulnerability Assessment — New HRIS

Remediated

- PDS saves — owner/admin checks **FIXED**
- Leave mutations — role-gated **FIXED**
- Form 6 IDOR — owner/staff guard **FIXED**

Reviewed clean

- SQLi — Spring Data queries
- XSS — Thymeleaf escaping
- CSRF — active on leave POSTs

Residual risks (follow-ups)

- Other modules still "authenticated-only" **MED**
- Sensitive data in git history **MED**
- Default password rotation **MED**
- HR nav for leave admin **LOW**

Two highest-impact exposures closed & verified; remaining items are hygiene/consistency, not active exploit paths.

Evidence & Proof of Changes

Claim	Artifact	Verify
Leave module added	d0d8be0	git show --stat d0d8be0
Leave authorization enforced	b10c18b	git show b10c18b
PDS access control	093043f	change log + commit
Leave schema	2026-leave-management.sql	open migration
Security parameters	SecurityConfig.java	read config

Visual proof: UAT screenshot sets (admin + employee) — PDS pages, dashboards, appointments, clearance, system settings, change-password.

Conclusion & Recommendations

Deployment verdict: **GO for the leave release** — follow migration-then-WAR order and back up the database first.

Prioritized recommendations

- **1** Force password change on first login (all accounts)
- **2** Extend role/ownership gating to appointments, clearance, 201-files
- **3** Scrub DB dumps & credentials from git history; rotate secrets
- **4** Run leave UAT and capture screenshots
- **5** Confirm HR navigation for leave admin